Report Esercizio W14D1 - Password Cracking con John the Ripper

Oct 18, 2026 - @Donato

Studente	Squicciarino Donato
Corso	Epicode - Cybersecurity & Ethical Hacker
Esercizio	W14D1 - Password Cracking
Scopo	Recuperare le password in chiaro a partire dagli hash MD5 estratti dal database tramite SQL Injection, eseguendo una sessione di cracking con John the Ripper

1. Obiettivo dell'esercizio

L'esercizio W14D1 del corso Epicode "Cybersecurity & Ethical Hacker" si ricollega direttamente all'esercizio W13D4: in quella sede era stata sfruttata una SQL Injection non blind sulla DVWA per estrarre dalla tabella `users` gli username e le relative password, risultate pero non in chiaro ma sotto forma di **hash MD5**.

L'obiettivo di questo esercizio e completare l'attacco portandolo fino in fondo: a partire dagli hash recuperati, eseguire una sessione di **password cracking offline** con lo strumento **John the Ripper**, per risalire alla versione in chiaro di tutte le password degli utenti del database.

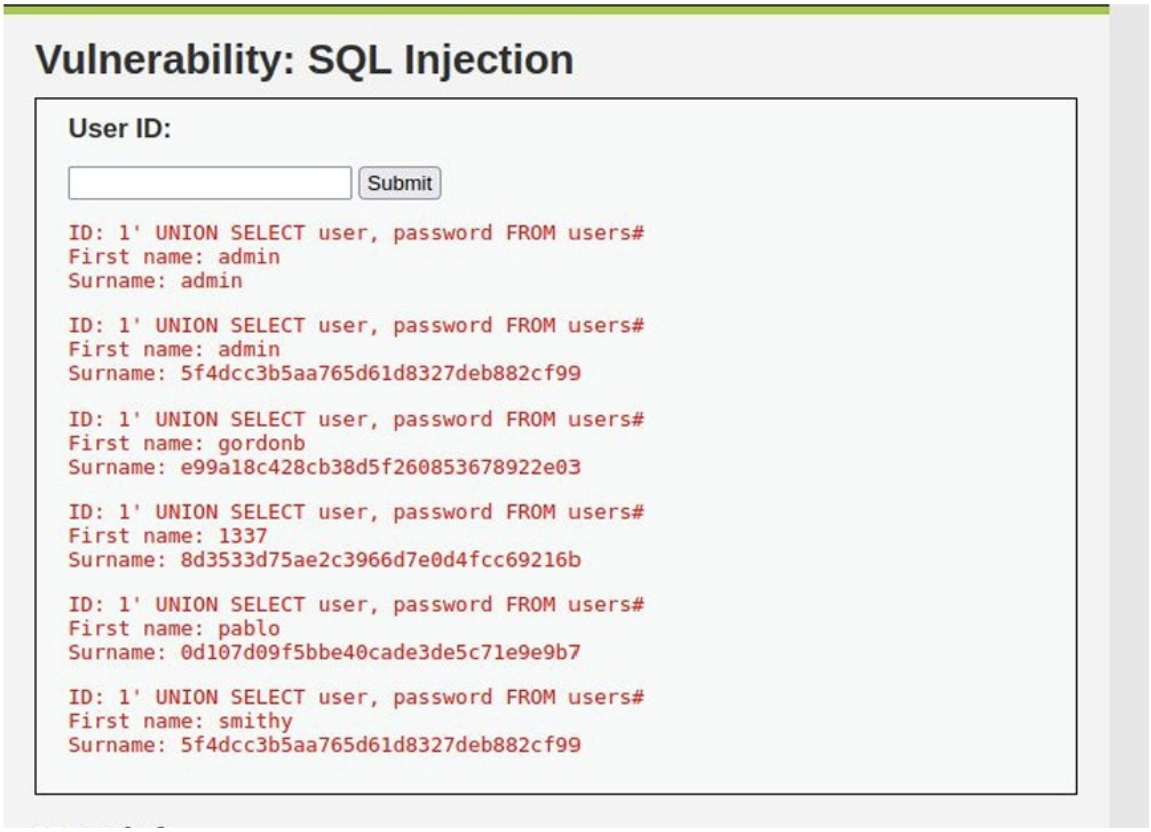
Questo passaggio e didatticamente importante perche mostra come un hash, da solo, non sia una protezione sufficiente: se l'algoritmo e debole (come MD5) e non prevede l'uso di un salt, chi riesce a sottrarre il database puo recuperare le password originali in tempi relativamente brevi, specialmente quando queste sono deboli o comuni.

2. Recupero degli hash dal database

Il punto di partenza e lo screenshot della SQL Injection gia effettuata nell'esercizio precedente, sulla sezione **Iniezione SQL** della DVWA, tramite il payload `1' UNION SELECT user, password FROM users#`. L'output mostra, per ciascuno dei cinque utenti presenti nella tabella `users` del database, lo username e il relativo hash della password:

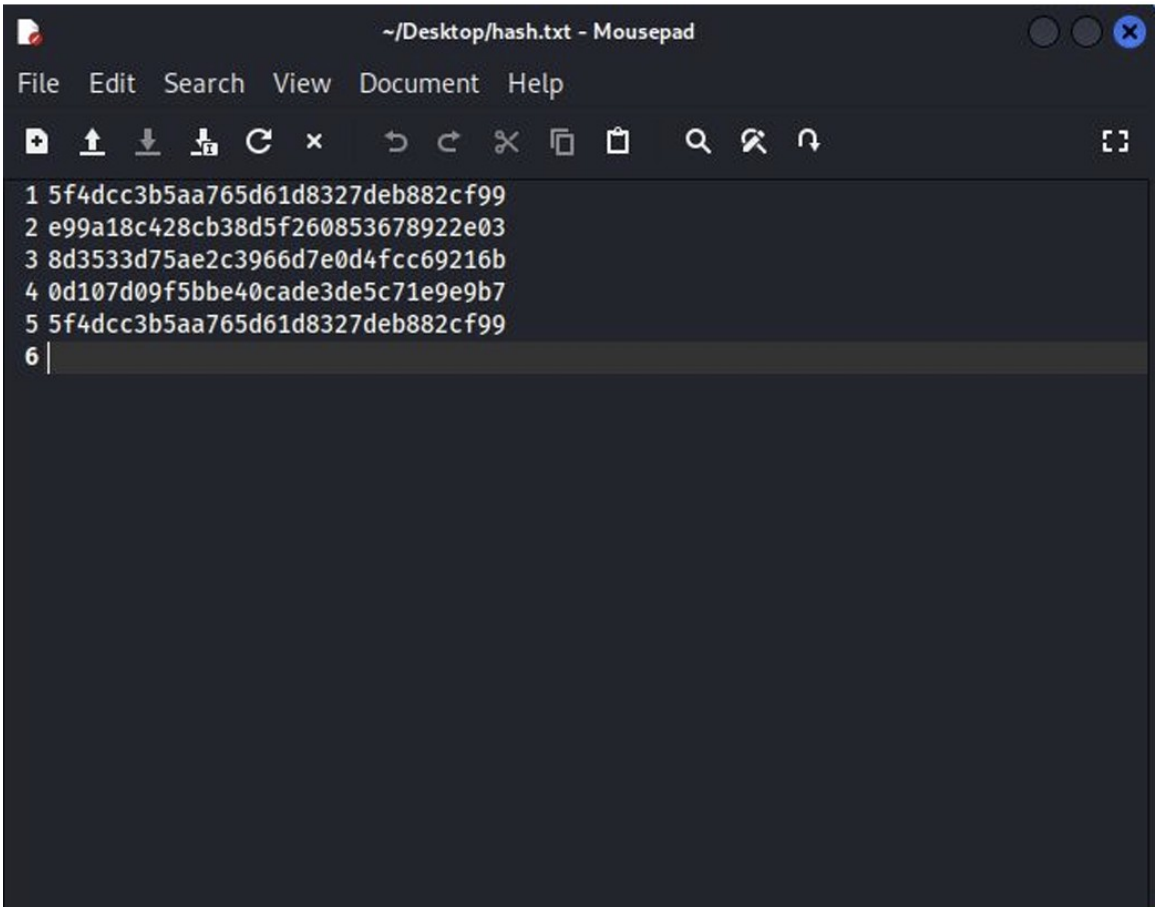
- `admin` -> `5f4dcc3b5aa765d61d8327deb882cf99`
- `gordonb` -> `e99a18c428cb38d5f260853678922e03`
- `1337` -> `8d3533d75ae2c3966d7e0d4fcc69216b`
- `pablo` -> `0d107d09f5bbe40cade3de5c71e9e9b7`
- `smithy` -> `5f4dcc3b5aa765d61d8327deb882cf99`

Si nota gia da questo output un dettaglio importante: `admin` e `smithy` condividono lo stesso hash (`5f4dcc3b5aa765d61d8327deb882cf99`), il che indica con alta probabilita che i due utenti usino la stessa password, anche prima di craccarla.



3. Tipologia e meccanismo del cracking

I cinque hash estratti sono stati copiati, uno per riga, in un file di testo (`hash.txt`) creato sul Desktop di Kali con l'editor grafico Mousepad, in modo da poterli passare in blocco a John the Ripper.



Tipologia di hash. Gli hash estratti sono a 32 caratteri esadecimali, la lunghezza tipica di un digest **MD5**. Si tratta inoltre di hash **non salati**: a conferma di cio, due utenti diversi (`admin` e `smithy`) presentano esattamente lo stesso hash per la stessa password, cosa impossibile se fosse stato usato un salt univoco per utente (che renderebbe diverso l'hash anche a parita di password in chiaro).

Perche MD5 e debole. MD5 e un algoritmo di hashing veloce, pensato originariamente per l'integrita dei dati e non per la protezione di password: proprio la sua velocita (miliardi di hash calcolabili al secondo su hardware moderno) lo rende inadatto a proteggere credenziali, perche un attaccante puo provare un numero enorme di combinazioni in poco tempo. L'assenza di salt aggrava il problema, perche permette di precalcolare tabelle di hash (rainbow table) o di riconoscere immediatamente password uguali tra utenti diversi.

Meccanismo di cracking scelto. Il comando utilizzato e stato:

```
john --show --format=Raw-MD5 /home/kali/Desktop/hash.txt
```

In realta il comando `--show` non esegue da solo l'attacco: mostra i risultati di una sessione di cracking gia lanciata in precedenza con `john --format=Raw-MD5 /home/kali/Desktop/hash.txt`, che di default usa la modalita a dizionario con la wordlist integrata di John the Ripper (`password.lst`), per poi passare automaticamente alla modalita incrementale (brute force) se il dizionario non e sufficiente. Il parametro `--format=Raw-MD5` indica esplicitamente a John il tipo di hash da interpretare, necessario perche un

hash MD5 "grezzo" (senza prefissi come quelli di `/etc/shadow`) non viene sempre riconosciuto automaticamente.

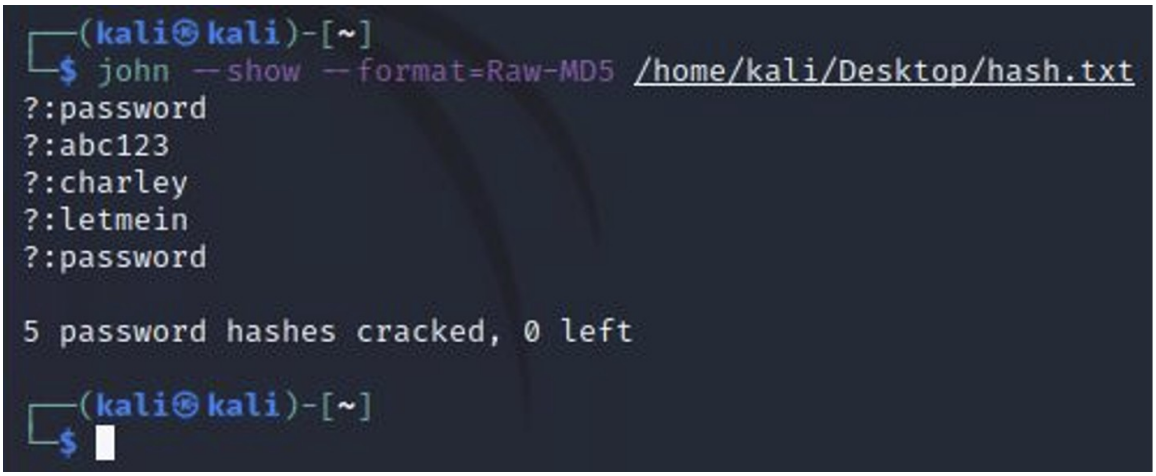
4. Esecuzione del cracking e risultato

Lo screenshot seguente mostra l'output del comando `john --show --format=Raw-MD5 /home/kali/Desktop/hash.txt`, eseguito al termine della sessione di cracking:

Hash	Password in chiaro
`5f4dcc3b5aa765d61d8327deb882cf99` (admin)	`password`
`e99a18c428cb38d5f260853678922e03` (gordonb)	`abc123`
`8d3533d75ae2c3966d7e0d4fcc69216b` (1337)	`charley`
`0d107d09f5bbe40cade3de5c71e9e9b7` (pablo)	`letmein`
`5f4dcc3b5aa765d61d8327deb882cf99` (smithy)	`password`

La riga finale `5 password hashes cracked, 0 left` conferma che **tutti e cinque gli hash** sono stati craccati con successo, senza alcun hash rimasto irrisolto: come anticipato, `admin` e `smithy` condividono infatti la stessa password (`password`), coerentemente con l'hash identico osservato nello screenshot della SQL Injection.

Il risultato e significativo: tutte le password recuperate sono estremamente deboli e presenti in qualunque dizionario comune (`password`, `abc123`, `letmein`), motivo per cui John the Ripper e riuscito a craccarle in pochi istanti con il solo attacco a dizionario, senza dover ricorrere a un piu lento brute force incrementale.



5. Conclusioni

L'esercizio ha completato la catena di attacco iniziata con la SQL Injection: dal semplice accesso in lettura al database, passando per l'esfiltrazione degli hash, fino alla loro completa decifrazione in chiaro tramite

un attacco a dizionario con John the Ripper. In pochi secondi e stato possibile risalire alle credenziali reali di tutti gli utenti della DVWA.

Il risultato mette in evidenza due problemi distinti ma correlati: da un lato l'uso di un algoritmo di hashing non adatto alla protezione di password (MD5, veloce e privo di salt), dall'altro l'uso di password estremamente deboli e comuni da parte degli utenti. Anche un algoritmo robusto non protegge una password banale, ma un algoritmo debole rende vulnerabile anche una password non scontata.

Le contromisure principali per questo tipo di scenario sono: adottare algoritmi di hashing pensati specificamente per le password e computazionalmente costosi (bcrypt, scrypt o Argon2, che rallentano deliberatamente ogni tentativo di verifica), utilizzare sempre un salt univoco per utente, e imporre policy di complessita minima sulle password scelte dagli utenti, cosi da rendere inefficace anche un attacco a dizionario.

L'esercizio ha permesso di capire in modo pratico perche il password hashing debole sia una delle cause piu comuni di compromissione su larga scala delle credenziali in caso di data breach, e perche la scelta dell'algoritmo di hashing sia una decisione di sicurezza tanto importante quanto la protezione del database stesso.

6. Esercizio facoltativo - Incident response su un PC Windows infettato da WannaCry

La traccia propone uno scenario di incident response: in qualita di consulente di sicurezza, si scopre che un computer Windows dell'azienda seguita e stato infettato dal ransomware **WannaCry**. Di seguito sono riportati l'intervento tempestivo da eseguire sul sistema infetto e le possibilita di messa in sicurezza successive, con relativi pro e contro.

6.1 Intervento tempestivo sul sistema infetto

1. **Isolare immediatamente la macchina dalla rete.** Scollegare subito il cavo di rete (o disattivare il Wi-Fi) del PC infetto, senza spegnerlo. WannaCry si propaga come un worm sfruttando la vulnerabilita SMB *EternalBlue* (porta 445): isolare la macchina e la prima azione da compiere, perche impedisce che il malware raggiunga altri PC e server nella stessa LAN.
2. **Non spegnere subito il PC.** Evitare uno shutdown immediato: la chiave di cifratura usata da WannaCry puo restare per un po' in RAM, e in alcuni casi strumenti come WanaKiwi/WannaKey sono riusciti a recuperarla da li. Spegnere o riavviare subito riduce drasticamente le possibilita di un eventuale recupero gratuito dei file.
3. **Documentare lo stato del sistema.** Fotografare la richiesta di riscatto, annotare orario dell'infezione, estensioni dei file cifrati ed eventuali messaggi di errore: la documentazione serve sia per un'eventuale analisi forense sia per segnalare l'incidente internamente o alle autorita competenti.
4. **Isolare backup e condivisioni collegate.** Scollegare (anche fisicamente) dischi esterni, NAS e cartelle di rete condivise montate sulla macchina infetta: WannaCry cifra anche i file raggiungibili su share di rete, quindi un backup ancora collegato rischia di essere cifrato a sua volta.

5. **Informare il team di sicurezza e la direzione.** Comunicare l'incidente al responsabile IT/sicurezza e, se sono coinvolti dati personali, valutare con il titolare del trattamento l'eventuale notifica al Garante Privacy entro 72 ore, come richiesto dal GDPR in caso di data breach.

6.2 Possibilita di messa in sicurezza del sistema

1. Reimaging completo + patch + restore da backup pulito. Formattare il disco, reinstallare Windows da zero applicando subito tutte le patch di sicurezza, poi ripristinare i dati da un backup precedente all'infezione (non collegato alla rete al momento dell'attacco).

- Pro: garanzia massima che il malware sia completamente eliminato
- Pro: ripristina anche i file, se esiste un backup pulito e recente
- Contro: tempo di fermo macchina piu lungo
- Contro: si perdono i dati prodotti dopo l'ultimo backup disponibile

2. Applicare la patch MS17-010 e bonificare con antivirus/EDR. Senza reinstallare da zero, applicare la patch Microsoft MS17-010 (che chiude la falla SMB EternalBlue), disattivare il protocollo obsoleto SMBv1 e rimuovere il malware con un antivirus o EDR aggiornato.

- Pro: tempo di ripristino piu rapido, minore interruzione operativa
- Pro: si possono recuperare i file non ancora cifrati al momento dell'intervento
- Contro: rischio che restino tracce nascoste o meccanismi di persistenza non rilevati
- Contro: i file gia cifrati restano cifrati (la patch previene, non decifra)

3. Tentare un recupero gratuito dei file con tool noti. Provare strumenti come WanaKiwi (basato su WannaKey), che su alcune versioni di Windows (XP/7) riescono a recuperare la chiave privata di cifratura se la RAM non e stata sovrascritta, cioe se il PC non e stato spento o riavviato dopo l'infezione.

- Pro: possibilita di recuperare i file senza pagare riscatto e senza perdita di dati
- Pro: nessun costo aggiuntivo da sostenere
- Contro: funziona solo in condizioni specifiche (PC non riavviato, memoria non sovrascritta, versione Windows compatibile)
- Contro: nessuna garanzia di successo, non sostituisce comunque bonifica e patching

4. Segmentazione di rete e hardening preventivo. Oltre a bonificare il singolo PC, isolare la rete aziendale in segmenti separati (VLAN), bloccare la porta 445 verso l'esterno sul firewall e rafforzare la postura di sicurezza generale per prevenire reinfezioni o la diffusione ad altri sistemi.

- Pro: riduce drasticamente il rischio di propagazione futura ad altri host
- Pro: migliora la sicurezza complessiva dell'infrastruttura, non solo del singolo PC
- Contro: richiede tempo, pianificazione e spesso investimenti su firewall/switch gestiti
- Contro: non risolve da solo l'infezione gia in corso sul PC coinvolto

6.3 Nota conclusiva

Nella pratica questi approcci non sono alternativi ma complementari: si isola subito la macchina, si tenta il recupero con WanaKiwi quando le condizioni lo permettono (senza nulla da perdere), si procede

comunque con reimaging o patching indipendentemente dall'esito del tentativo di decifratura, e infine si applica la segmentazione di rete come misura preventiva per l'intera infrastruttura aziendale.